

MANUAL DEL SGSI

PROPÓSITO, METAS Y OBJETIVOS

El propósito de este Sistema de Gestión de Seguridad de la Información (SGSI) es proteger los activos de información del ecosistema universitario contra amenazas internas y externas, garantizando la continuidad de las operaciones académicas e investigadoras.

- **Meta Principal:** Proteger la confidencialidad, integridad y disponibilidad (Tríada CID) de los datos de la comunidad universitaria y los sistemas que los soportan.
- **Objetivos:**
 1. Garantizar la continuidad del negocio institucional (minimizar el tiempo de inactividad de las plataformas de aprendizaje y gestión).
 2. Proteger la propiedad intelectual de los proyectos de investigación científica.
 3. Asegurar el cumplimiento de las normativas de privacidad y protección de datos estudiantiles y financieros.

1. DEFINICION DEL ALCANCE

1.1 IDENTIFICACIÓN Y CLASIFICACIÓN DE ACTIVOS DE INFORMACIÓN

Para acotar el SGSI, los activos se dividen en cuatro categorías esenciales y se clasifican según su criticidad para el funcionamiento de la universidad:

Categoría de Activo	Descripción del Activo	Criticidad
Datos / Información	Expedientes académicos, calificaciones e información financiera de estudiantes.	Crítico
Datos / Información	Patentes, datos crudos y resultados de investigaciones científicas en curso.	Alto
Software / Sistemas	Sistema de Información de Estudiantes (SIS) y Plataforma de Aprendizaje (Ej: Canvas / Moodle).	Crítico
Hardware / Infraestructura	Servidores del Centro de Datos Principal y supercomputadores de investigación.	Alto
Personal	Investigadores principales, administradores de sistemas TI y personal de admisiones.	Alto
Hardware / Dispositivos	Computadoras de laboratorios de alumnos y laptops del personal administrativo.	Medio

1.2 LÍMITES FÍSICOS Y ÁREAS RESTRINGIDAS

El alcance físico comprende el Campus Central de la Universidad, incluyendo las siguientes zonas específicas donde se procesa o almacena información:

- **Zonas de Acceso General:** Aulas, bibliotecas principales y oficinas de atención al estudiante.
- **Áreas Restringidas (Controles de Acceso Estrictos):**
 - **Centro de Datos del Campus:** Acceso exclusivo a ingenieros de sistemas mediante biometría y tarjeta de proximidad.
 - **Laboratorios de Investigación Tecnológica/Científica:** Acceso limitado a investigadores autorizados.
 - **Oficinas de Dirección Financiera y Archivo Central:** Acceso exclusivo a personal de nóminas y matrículas.

1.3 LÍMITES VIRTUALES Y TECNOLÓGICOS

El SGSI cubrirá el espacio lógico operado por la universidad, especificando los siguientes entornos:

- **Redes:** Red corporativa administrativa (segmentada), Red de investigación y Red Wi-Fi pública para estudiantes (aislada mediante VLANs).
- **Entornos Cloud y Virtualización:** Infraestructura de servidores virtuales (operada en entornos controlados como VirtualBox para pruebas y VMware para producción), junto con el almacenamiento institucional en la nube (Google Workspace / MS Azure).
- **Exclusiones Explícitas:** Quedan fuera del alcance del SGSI los dispositivos personales (BYOD) de los estudiantes y profesores cuando se conectan desde redes externas domésticas, limitando la responsabilidad de la universidad a los portales de autenticación de acceso.

1.4 PARTES INTERESADAS Y MATRIZ DE RESPONSABILIDADES

Para que el SGSI funcione, se definen los siguientes actores y sus responsabilidades clave dentro de la estructura formal de seguridad:

- **Alta Dirección (Rectorado / Consejo Universitario):** Proporciona los recursos financieros, aprueba formalmente las políticas de seguridad y demuestra liderazgo.
- **Oficina de Seguridad de la Información (CISO / Equipo de TI):** Diseña, implementa y monitorea los controles de seguridad; lidera la respuesta ante incidentes.
- **Personal Administrativo y Docente:** Cumplir las políticas establecidas (uso de contraseñas robustas, bloqueo de pantallas, reporte de correos sospechosos).
- **Estudiantes / Usuarios de Servicios:** Utilizar de manera ética y segura los recursos informáticos provistos por la universidad.

2. EVALUACION DE RIESGOS

2.1 INVENTARIO Y CLASIFICACIÓN COMPLETA DE ACTIVOS

Para realizar un análisis de riesgos riguroso, se desglosan los activos de la universidad identificados en el alcance, categorizados formalmente en: Hardware, Software, Datos y Personal. Cada uno cuenta con un identificador único para su trazabilidad.

ID Activo	Nombre del Activo	Categoría	Descripción / Función	Criticidad
ACT-HW-01	Servidores del Centro de Datos Principal	Hardware	Servidores físicos en el campus que alojan las bases de datos y la red central.	Alta
ACT-HW-02	Supercomputador de Investigación	Hardware	Infraestructura de cómputo de alto rendimiento dedicada a proyectos de I+D.	Alta
ACT-HW-03	Equipos de Laboratorios y Aulas	Hardware	Computadoras de escritorio utilizadas por estudiantes y profesores en clases.	Media
ACT-SW-01	Sistema de Información de Estudiantes (SIS)	Software	Aplicación web para inscripciones, expedientes académicos, actas y notas.	Crítica
ACT-SW-02	Plataforma de Aprendizaje (Canvas / Moodle)	Software	Aula virtual para la entrega de tareas, exámenes en línea y material docente.	Crítica
ACT-SW-03	Portal de Gestión Financiera y Nóminas	Software	Sistema informático para el pago de matrículas, salarios del personal y presupuestos.	Alta
ACT-DAT-01	Expedientes y Datos Personales de Alumnos	Datos	Bases de datos con registros médicos, financieros e información de contacto.	Crítica
ACT-DAT-02	Propiedad Intelectual y Patentes	Datos	Resultados científicos, códigos fuente de proyectos e investigaciones financiadas.	Alta
ACT-PER-01	Administradores de Sistemas y TI	Personal	Personal con credenciales privilegiadas de acceso a la infraestructura de red.	Alta
ACT-PER-02	Docentes e Investigadores	Personal	Usuarios internos que generan conocimiento científico y gestionan notas.	Media

2.2 IDENTIFICACIÓN DE AMENAZAS POTENCIALES (INTERNAS Y EXTERNAS)

Las amenazas se definen como cualquier evento que pueda causar un impacto negativo en la confidencialidad, integridad o disponibilidad de los activos.

- **Amenazas Externas (Origen fuera de la red universitaria):**
 1. **Ataques de Ransomware / Malware Avanzado:** Código malicioso inyectado con el fin de cifrar los servidores y exigir un rescate económico.
 2. **Ataques de Denegación de Servicio Distribuido (DDoS):** Inundación de tráfico malicioso dirigido al portal de exámenes o matrículas para provocar su caída.
 3. **Ciberspionaje e Intrusiones Dirigidas:** Actores externos intentando acceder a los repositorios de patentes científicas para robo de propiedad intelectual.
 4. **Desastres Naturales / Incidentes de Infraestructura:** Cortes de energía prolongados, inundaciones o incendios que afecten físicamente al centro de datos.
- **Amenazas Internas (Origen dentro de la propia organización):**
 1. **Ataques de Phishing e Ingeniería Social:** Empleados o estudiantes que involuntariamente introducen sus credenciales en portales falsos, entregando el control a atacantes.
 2. **Abuso de Privilegios / Sabotaje Interno:** Usuarios con acceso autorizado (ej. alumnos descontentos o personal con privilegios elevados) que alteren calificaciones o eliminen configuraciones.
 3. **Fugas de Información Involuntarias:** Investigadores o administrativos que suben datos sensibles a nubes públicas no autorizadas o pierden dispositivos institucionales.

2.3 IDENTIFICACIÓN DE VULNERABILIDADES Y MECANISMO DE EXPLOTACIÓN

Las vulnerabilidades son las debilidades técnicas, físicas u organizativas existentes en los activos que permiten a las amenazas materializarse.

- **Vulnerabilidad 1: Falta de cifrado en almacenamiento (Datos en reposo):**
 - *Cómo podría explotarse:* Si un atacante vulnera el perímetro de la red o roba físicamente un disco duro del supercomputador, podrá extraer directamente los resultados de las patentes científicas sin necesidad de romper contraseñas.
- **Vulnerabilidad 2: Políticas de contraseñas débiles y ausencia de MFA (Autenticación Multifactor):**
 - *Cómo podría explotarse:* Mediante ataques automatizados de fuerza bruta (usando herramientas como Hydra) o campañas dirigidas de Phishing. Una vez obtenida la contraseña simple de un docente, el atacante accede al SIS y modifica notas libremente.
- **Vulnerabilidad 3: Sistemas operativos y software desactualizados:**

- *Cómo podría explotarse:* Servidores o plataformas web (Moodle/Canvas) que no aplican parches de seguridad de forma periódica son vulnerables a exploits públicos conocidos que permiten la ejecución remota de código (RCE) y la elevación de privilegios a Root.
- **Vulnerabilidad 4: Ausencia de aislamiento/segmentación de redes y reglas de filtrado laxas:**
 - *Cómo podría explotarse:* Si un alumno conecta un equipo infectado en el Wi-Fi público del campus, la falta de segmentación (VLANs) permitiría al malware propagarse lateralmente hasta la red administrativa interna y los servidores de bases de datos centrales.
- **Vulnerabilidad 5: Carencia de planes de copias de seguridad inmutables u offline:**
 - *Cómo podría explotarse:* En un ataque de Ransomware, si las copias de seguridad están conectadas permanentemente a la misma red de producción, el malware las cifrará al mismo tiempo que los servidores principales, eliminando toda capacidad de recuperación.

2.4 EVALUACIÓN DE PROBABILIDAD E IMPACTO (CRITERIO CUALITATIVO)

Para cuantificar la severidad de cada riesgo, se utiliza una escala de tres niveles (**Bajo, Medio, Alto**), definida bajo los siguientes parámetros de impacto institucional:

- **Probabilidad:** **Baja** (Inusual / Requiere alta sofisticación), **Media** (Factible / Ocurre ocasionalmente en el sector educativo), **Alta** (Muy probable / Intrepidamente frecuente).
- **Impacto:** **Bajo** (Inconveniente menor sin pérdida de datos), **Medio** (Interrupción temporal de servicios o fuga parcial sin datos críticos), **Alto** (Paralización total, multas por leyes de privacidad, pérdida irreversible de propiedad intelectual o daño severo a la reputación pública).

2.5 MATRIZ Y PRIORIZACIÓN DE RIESGOS DEL SGSI

Al cruzar la probabilidad y el impacto, se consolida la lista priorizada de riesgos que requieren acciones preventivas inmediatas en el manual:

ID Riesgo	Activo Relacionado	Amenaza + Vulnerabilidad Combinada	Probabilidad	Impacto	Calificación del Riesgo	Prioridad de Mitigación
R-01	ACT-SW-01 ACT-DAT-01	Ataque de Ransomware explotando la falta de backups offline y sistemas desactualizados en la base de datos de estudiantes (SIS).	Alta	Alto	ALTO	1º - Inmediata
R-02	ACT-DAT-02	Exfiltración de patentes/investigaciones debido a la falta de cifrado en reposo y control laxo de privilegios mínimos.	Media	Alto	ALTO	2º - Inmediata
R-03	ACT-SW-02	Denegación de servicio (DDoS) en plataformas de examen (Moodle) debido a la falta de reglas de mitigación perimetral y firewalls laxos.	Alta	Medio	MEDIO	3º - Corto Plazo
R-04	ACT-PER-01 ACT-PER-02	Suplantación de identidad por Phishing masivo aprovechando la ausencia de Autenticación de Múltiple Factor (MFA).	Alta	Medio	MEDIO	4º - Corto Plazo
R-05	ACT-HW-01	Acceso físico no autorizado al centro de datos principal debido al uso de cerraduras mecánicas tradicionales sin registro.	Baja	Alto	MEDIO	5º - Mediano Plazo
R-06	ACT-HW-03	Infección por malware común en computadoras de laboratorios públicos debido al uso de cuentas con privilegios de administrador por alumnos.	Alta	Bajo	BAJO	6º - Monitorear

3. SELECCIÓN DE CONTROLES

3.1 REVISIÓN DE NORMAS RELEVANTES Y MARCO REGULATORIO

Para dar respuesta a los riesgos identificados en la sección anterior, la Universidad Pública toma como marcos de referencia internacionales y sectoriales los siguientes estándares:

- **ISO/IEC 27001:2022 (Anexo A):** Proporciona la estructura de controles organizativos, físicos, tecnológicos y de personas necesarios para la certificación formal.
- **NIST SP 800-53:** Utilizado específicamente para fortalecer los controles de sistemas de información federales y de organizaciones gubernamentales.
- **Marco de Privacidad y Regulaciones Públicas:** Cumplimiento estricto de las leyes nacionales de protección de datos personales (como el RGPD o el Esquema Nacional de Seguridad según aplique geográficamente) aplicables a las bases de datos de estudiantes y nóminas.

3.2 SELECCIÓN Y MAPEO DE CONTROLES BASADOS EN EL RIESGO

Teniendo en cuenta las limitaciones presupuestarias típicas del sector público, se han seleccionado controles altamente efectivos que aprovechan al máximo el software libre (como configuraciones nativas de Linux y firewalls de código abierto) y la infraestructura actual de la universidad.

A continuación, se documenta detalladamente cada control seleccionado, su mecanismo de mitigación y los roles asignados para su despliegue y supervisión:

CONTROL 1: Protección contra Ransomware y Pérdida de Datos (Para mitigar R-01)

- **Referencia:** ISO 27001:2022 A.8.13 (Copias de seguridad) & A.8.19 (Gestión de vulnerabilidades técnicas).
- **Descripción de la Implementación:** Se implementa una política estricta de respaldo bajo el esquema **3-2-1 Inmutable**. Se realizarán 3 copias de los expedientes académicos (SIS), en 2 soportes diferentes, almacenando 1 réplica en un servidor *offline* (completamente aislado de la red de producción) que impida su modificación o borrado incluso si las credenciales de administrador se ven comprometidas. Adicionalmente, se programarán escaneos trimestrales de vulnerabilidades mediante herramientas automatizadas en los servidores del SIS.
- **Rol Responsable:** Administrador de Bases de Datos (Implementación) y CISO / Administrador de Sistemas (Supervisión).

CONTROL 2: Cifrado y Control de Accesos de Investigaciones (Para mitigar R-02)

- **Referencia:** ISO 27001:2022 A.8.24 (Uso de criptografía) & A.8.12 (Gestión de privilegios de acceso).
- **Descripción de la Implementación:** Aplicación estricta del principio de "privilegio mínimo" mediante listas de control de acceso (ACLs) y Roles de Usuario (RBAC). Los investigadores solo tendrán acceso de lectura y escritura a sus propios proyectos de I+D. Todos los datos de patentes científicas almacenados en el Supercomputador o en repositorios lógicos de almacenamiento compartido se cifrarán utilizando el estándar de cifrado avanzado **AES-256**.
- **Rol Responsable:** Administrador de Infraestructura Cloud y Almacenamiento (Implementación).

CONTROL 3: Mitigación de Ataques DDoS en Época de Exámenes (Para mitigar R-03)

- **Referencia:** ISO 27001:2022 A.8.20 (Seguridad de las redes) & A.8.22 (Filtrado de la web).
- **Descripción de la Implementación:** Despliegue perimetral de un Sistema de Detección y Prevención de Intrusiones (IDS/IPS) basado en **Suricata**. Configuración avanzada de reglas en los firewalls de los servidores web (**iptables**) para aplicar limitaciones de tasa (*rate-limiting*) por dirección IP en conexiones entrantes HTTP/HTTPS. Esto evitará que ráfagas automatizadas de tráfico tumben las plataformas virtuales de aprendizaje durante las entregas críticas.
- **Rol Responsable:** Ingeniero de Redes y Seguridad Perimetral.

CONTROL 4: Autenticación Robusta contra Phishing (Para mitigar R-04)

- **Referencia:** ISO 27001:2022 A.5.15 (Control de acceso) & A.6.3 (Concienciación en seguridad).
- **Descripción de la Implementación:** Despliegue e integración obligatoria de **Autenticación Multifactor (MFA)** para todas las cuentas del dominio institucional (estudiantes, profesores y personal administrativo). El acceso requerirá validación mediante una aplicación autenticadora. Se complementará con bloqueos geográficos para accesos desde países no habituales.
- **Rol Responsable:** Administrador de Identidades / Mesa de Ayuda TI (Implementación).

CONTROL 5: Control de Acceso Físico al Centro de Datos (Para mitigar R-05)

- **Referencia:** ISO 27001:2022 A.7.4 (Supervisión de la seguridad física).
- **Descripción de la Implementación:** Reemplazo total de cerraduras con llave metálica en las salas de servidores principales por un sistema de acceso electrónico controlado mediante **tarjeta inteligente RFID combinada con verificación biométrica** (huella dactilar). El sistema generará alertas ante intentos de acceso fallidos o puertas abiertas por más de 30 segundos.
- **Rol Responsable:** Director de Servicios Generales y Seguridad Física (Implementación).

3.3.1 PLANIFICACIÓN DE LA IMPLEMENTACIÓN Y CRONOGRAMA

La ejecución de estos controles se distribuye en un horizonte temporal de **6 meses**, estructurado en fases de criticidad para garantizar que la operatividad de la universidad no se vea afectada y respetando los ciclos presupuestarios públicos.

Fase 1: Inmediata (Meses 1-2) | (MFA Obligatorio y Backups Inmutables del SIS)

Fase 2: Corto Plazo (Meses 3-4) | (Suricata/iptables contra DDoS y Cifrado AES-256)

Fase 3: Mediano Plazo (Meses 5-6) | (Control Biométrico en Centro de Datos)

3.3.2 REQUISITOS PREVIOS Y DEPENDENCIAS CRÍTICAS

Para asegurar el éxito del despliegue, el equipo de consultoría identifica las siguientes dependencias técnicas y operativas:

1. **Dependencia para MFA (Fase 1):** Es indispensable contar con un inventario depurado de cuentas de correo institucionales activas. Las cuentas en desuso o de alumnos egresados deben ser suspendidas previamente para evitar brechas ocultas.

2. **Dependencia para Suricata/Firewall (Fase 2):** Los ajustes de reglas en los firewalls perimetrales deben testearse primero en entornos virtuales aislados de pruebas (como laboratorios controlados en VirtualBox) antes de pasar a producción, evitando falsos positivos que puedan bloquear el tráfico legítimo de los estudiantes en días de exámenes.
3. **Dependencia para el Centro de Datos (Fase 3):** Requiere la aprobación de la partida presupuestaria de infraestructuras físicas por parte de la Gerencia/Rectorado de la universidad y la licitación del proveedor de seguridad electrónica.

4. DOCUMENTACIÓN DE POLÍTICAS Y PROCEDIMIENTOS DE SEGURIDAD

4.1.1 DECLARACIÓN DE COMPROMISO INSTITUCIONAL

La Universidad Pública, en su compromiso con la excelencia académica, la investigación científica y la transparencia en la gestión de los recursos ciudadanos, reconoce que la información es uno de sus activos más valiosos. La Dirección de la Universidad se compromete formalmente a desarrollar, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información (SGSI) alineado con la norma ISO/IEC 27001.

4.1.2 PRINCIPIOS CLAVE DE SEGURIDAD

Toda actividad de tratamiento de datos, diseño de infraestructura o comportamiento del personal dentro de la Universidad deberá regirse por la Tríada CID:

- **Confidencialidad:** Garantizar que los datos personales de estudiantes, expedientes académicos e investigaciones protegidas sean accesibles únicamente por el personal explícitamente autorizado.
- **Integridad:** Salvaguardar la exactitud y completitud de las calificaciones, registros financieros y patentes científicas, evitando cualquier alteración maliciosa o accidental.
- **Disponibilidad:** Asegurar que las plataformas de aprendizaje (Moodle/Canvas), portales administrativos y sistemas de red estén operativos y accesibles para la comunidad universitaria siempre que se requiera

4.2 POLÍTICA DE CONTROL DE ACCESO DE USUARIOS Y CONTRASEÑAS

4.2.1 CICLO DE VIDA DE LAS CUENTAS DE USUARIO (CONCESIÓN, MODIFICACIÓN, REVOCACIÓN)

- **Alta (Concesión):** El acceso a los sistemas se otorga bajo el principio de "privilegio mínimo" y "necesidad de conocer". Las cuentas de estudiantes se generan automáticamente tras la matriculación oficial. Las cuentas del personal administrativo/docente requieren una solicitud formal de su jefe de departamento a la Oficina de TI.
- **Modificación:** Cualquier cambio en las funciones o departamentos de un empleado conllevará una revisión técnica inmediata de sus permisos para revocar los accesos del rol anterior y asignar los nuevos.
- **Baja (Revocación):** El acceso se suspenderá de forma inmediata al finalizar el contrato laboral, rescisión, expulsión o graduación del usuario. Las cuentas inactivas se deshabilitarán automáticamente tras 90 días sin uso.

4.2.2 ESTÁNDAR TÉCNICO DE CONTRASEÑAS Y AUTENTICACIÓN

- **Complejidad:** Longitud mínima de 12 caracteres, incluyendo obligatoriamente mayúsculas, minúsculas, números y al menos un carácter especial (ej. \$, #, @, *).
- **Rotación:** Las contraseñas del personal administrativo y con privilegios elevados (TI) deben cambiarse cada 180 días. Las cuentas de estudiantes se rotarán anualmente.
- **Historial y Bloqueo:** No se podrán reutilizar las últimas 5 contraseñas. La cuenta se bloqueará automáticamente tras 5 intentos fallidos consecutivos durante un periodo de 15 minutos.
- **MFA:** Es obligatorio el uso de Autenticación de Múltiple Factor (MFA) vía aplicación OTP para todo acceso externo a la red institucional o portales web críticos.

4.3 PLAN DE RESPUESTA A INCIDENTES DE SEGURIDAD (PRIS)

4.3.1 DEFINICIÓN DE INCIDENTE DE SEGURIDAD

Se define como cualquier evento adverso, confirmado o bajo sospecha, que comprometa la confidencialidad, integridad o disponibilidad de los sistemas o datos de la Universidad (ej. infección por ransomware, sospecha de phishing, caída del campus virtual por DDoS, robo físico de una laptop institucional).

4.3.2 ROLES Y RESPONSABILIDADES EN CRISIS

- **Comité de Respuesta a Incidentes (CRI):** Liderado por el CISO, coordinado con el Administrador de Redes y un representante del gabinete legal.
- **Primer Respondiente:** Cualquier usuario o técnico de soporte que detecte la anomalía y realice la notificación inicial.

4.3.3 PROCEDIMIENTO PASO A PASO ANTE INCIDENTES

[1. Identificación] —> [2. Contención] —> [3. Mitigación] —> [4. Lecciones Aprendidas]

- **Fase 1: Identificación y Reporte:** El usuario o las alertas automáticas de **Suricata** detectan un comportamiento anómalo. Se genera un ticket interno categorizando el incidente (Bajo, Medio, Alto).
- **Fase 2: Contención Inmediata:** Para evitar la propagación (ej. Ransomware), el equipo de TI aislará lógicamente los servidores afectados apagando interfaces de red o aplicando reglas de bloqueo estrictas en **iptables**.
- **Fase 3: Mitigación y Erradicación:** Se eliminan los vectores de ataque (malware, cuentas comprometidas) y se procede a la restauración controlada de los sistemas utilizando las copias de seguridad inmutables.
- **Fase 4: Recuperación y Lecciones Aprendidas:** Vuelta a la producción normal. En un plazo máximo de 72 horas, el CRI redactará un informe forense detallando la causa raíz, el impacto y las mejoras necesarias para evitar su repetición.

4.4 PROCEDIMIENTO DE COPIA DE SEGURIDAD Y RECUPERACIÓN DE DATOS

4.4.1 FRECUENCIA Y ALCANCE DE LOS RESPALDOS

- **Datos Críticos (Bases de datos SIS, Notas, Finanzas):** Respaldo incremental diario y respaldo completo semanal de forma automatizada con scripts cron en servidores Debian dedicados.
- **Datos de Investigación y Configuración:** Respaldo semanal incremental.
- **Cifrado y Almacenamiento:** Todas las copias se cifrarán en tránsito y en reposo utilizando AES-256. Se mantendrá una copia local y una réplica externa inmutable (*offline*).

4.4.2 RESPONSABLES Y PRUEBAS DE RECUPERACIÓN

- **Responsable:** El Administrador de Bases de Datos (DBA) es el encargado de supervisar el correcto estado de los logs de respaldo cada mañana.
- **Pruebas de Verificación:** El último sábado de cada mes se realizarán pruebas de restauración aleatorias en un entorno virtual aislado (ej. VirtualBox) para calcular el RTO (Tiempo de Recuperación) real y certificar que los archivos no están corruptos.

4.5 PLAN DE CONCIENCIACIÓN Y CAPACITACIÓN DE EMPLEADOS

4.5.1 PROGRAMA ACADÉMICO DE CIBERSEGURIDAD INTERNA

Todo el personal de la universidad (docentes, investigadores y administrativos) debe completar obligatoriamente un taller de concienciación de 2 horas al ingresar a la institución, con actualizaciones anuales de 45 minutos a través de la plataforma virtual.

4.5.2 MATERIALES DE DIFUSIÓN Y BUENAS PRÁCTICAS

- **Campañas de Simulación:** La Oficina de Seguridad ejecutará simulacros periódicos e inopinados de phishing por correo electrónico para medir la capacidad de detección de los empleados.
- **Directrices y Cartelería Digital:** Distribución mensual de infografías interactivas a través de las pantallas del campus y portales internos enfocadas en:
 - El peligro de conectar memorias USB desconocidas en los laboratorios.
 - Bloqueo obligatorio de pantalla (Win + L) al levantarse del puesto administrativo.
 - Cómo identificar un correo electrónico fraudulento (remitentes extraños, enlaces).

4.6 APROBACIÓN, REVISIÓN Y CONTROL DOCUMENTAL

4.6.1 FLUJO DE APROBACIÓN FORMAL

Ninguna política o procedimiento técnico del SGSI entrará en vigor ni será vinculante sin pasar por el siguiente proceso de revisión:

1. **Elaboración:** Diseñado y redactado por el CISO y el equipo técnico de seguridad de TI.
2. **Revisión:** Evaluado por la Asesoría Jurídica de la universidad para garantizar conformidad con las leyes de protección de datos vigentes.
3. **Aprobación:** Ratificado formalmente mediante firma por el Rector de la Universidad.

4.6.2 CRONOGRAMA DE ACTUALIZACIÓN PERIÓDICA

Todos los documentos que componen el Manual del SGSI se revisarán de forma obligatoria **una vez al año** durante el primer trimestre, o de manera extraordinaria e inmediata si ocurre un incidente de seguridad grave, cambios estructurales de gran envergadura en la infraestructura de la red, o modificaciones en la legislación del sector público.

5. MARCO DE GOBERNANZA, MONITOREO Y MEJORA CONTINUA

5.1 ORGANIZACIÓN Y COMPILACIÓN ESTRUCTURADA DEL MANUAL

Este documento constituye el **Manual Maestro del Sistema de Gestión de Seguridad de la Información (SGSI)** de la Universidad Pública. Su objetivo es unificar las directrices estratégicas, los análisis técnicos y el marco normativo bajo una estructura única e integrada.

El diseño del Manual sigue fielmente el ciclo de mejora continua **PHVA (Planificar, Hacer, Verificar, Actuar)** de la norma ISO/IEC 27001, quedando consolidado bajo el siguiente índice oficial de secciones desarrolladas a lo largo de este proyecto:

- **Sección 1:** Introducción y Objetivos Estratégicos Institucionales.
- **Sección 2:** Definición del Alcance y Límites (Físicos, Virtuales y Exclusiones).
- **Sección 3:** Metodología y Matriz de Evaluación de Riesgos de la Información.
- **Sección 4:** Selección, Declaración de Aplicabilidad y Plan de Implementación de Controles.
- **Sección 5:** Cuerpo Normativo (Políticas de Acceso, Contraseñas, Respaldos y Concienciación).
- **Sección 6:** Estructura de Gobernanza, Roles, Métricas de Monitoreo y Plantillas Operativas.

5.2 COMPROMISO DEL LIDERAZGO, ROLES Y RESPONSABILIDADES

5.2.1 DECLARACIÓN DE COMPROMISO DE LA ALTA DIRECCIÓN (RECTORADO)

El Consejo de Gobierno y el Rectorado de la Universidad Pública declaran su apoyo incondicional al SGSI mediante las siguientes acciones de liderazgo:

1. Garantizar la asignación anual de los recursos financieros, técnicos y humanos necesarios para la ejecución del plan de controles.
2. Integrar los objetivos de seguridad de la información dentro de la planificación estratégica y los planes de estudio de la universidad.
3. Promover activamente una cultura institucional orientada a la ciberseguridad y la protección de los datos de los ciudadanos.

5.2.2 MATRIZ DE ROLES Y RESPONSABILIDADES DEL SGSI

Para asegurar el correcto mantenimiento del sistema, se formalizan las atribuciones de los siguientes roles clave:

- **Comité de Seguridad de la Información (CSI):**

- *Composición:* Rector (o delegado), CISO, Director de TI y Responsable de Asesoría Jurídica.
- *Responsabilidad:* Revisar el estado del SGSI semestralmente, aprobar cambios mayores en las políticas y actuar como máxima autoridad en la gestión de incidentes graves.
- **Oficina del CISO (Chief Information Security Officer):**
 - *Responsabilidad:* Coordinar la implementación técnica del SGSI, liderar las auditorías internas, realizar las evaluaciones de riesgos anuales y actualizar los controles perimetrales (IDS/Firewalls).
- **Administradores de Sistemas, Redes y Bases de Datos (Equipo de TI):**
 - *Responsabilidad:* Ejecutar los procedimientos técnicos operativos cotidianos: verificar logs, aplicar parches de seguridad, gestionar la inmutabilidad de los respaldos en servidores Debian y ajustar las reglas de *iptables* o *Suricata*.
- **Usuarios Finales (Personal Administrativo, Docentes, Investigadores y Alumnos):**
 - *Responsabilidad:* Conocer y cumplir las políticas de contraseñas, reportar inmediatamente cualquier actividad sospechosa (como intentos de phishing) y proteger sus credenciales de acceso institucional utilizando obligatoriamente el MFA.

5.3 DOCUMENTACIÓN DETALLADA DE LA METODOLOGÍA Y PLANTILLAS DE RIESGO

El proceso de gestión de riesgos sigue una metodología estructurada de mejora constante. La identificación de riesgos no es un evento único, sino un ciclo recurrente. A continuación, se definen los estándares de cálculo y se anexan los formularios operativos oficiales que utilizará la Oficina del CISO para las auditorías anuales:

5.3.1 CRITERIO DE CÁLCULO OPERATIVO

El nivel de riesgo se obtiene mediante el producto de los valores asignados a la probabilidad y el impacto, utilizando la siguiente matriz de referencia numérica:

Impacto / Probabilidad	Bajo (1)	Medio (2)	Alto (3)
Alta (3)	3 (Medio)	6 (Alto)	9 (Crítico)
Media (2)	2 (Bajo)	4 (Medio)	6 (Alto)
Baja (1)	1 (Bajo)	2 (Bajo)	3 (Medio)

5.3.2 FORMULARIO OFICIAL ANEXO A: REGISTRO E IDENTIFICACIÓN DE NUEVOS RIESGOS

(Esta plantilla en blanco se incorpora al manual para ser utilizada por los líderes de departamento al detectar un nuevo activo o amenaza):

=====

FORMULARIO DE CONTROL: REGISTRO DE RIESGOS DEL SGSI (CÓDIGO: FM-RSK-01)

===== Fecha

de Registro: [DD / MM / AAAA] Departamento/Facultad: [] Responsable del Activo: [] ID del Activo: []

1. DESCRIPCIÓN DEL RIESGO ----- Amenaza

Identificada: _____ Vulnerabilidad

Explotable: _____ 2. EVALUACIÓN

CUALITATIVA INICIAL ----- Probabilidad

Estimada (Baja / Media / Alta): [] -> Valor (1-3): [] Impacto Estimado (Bajo / Medio / Alto): [] -> Valor (1-3): [] NIVEL DE RIESGO CALCULADO (Probabilidad x Impacto): [] 3. PROPUESTA DE MITIGACIÓN (A rellenar por la Oficina del CISO) ----- Control ISO

27001 Propuesto: _____ Fecha Límite de

Implementación: [DD / MM / AAAA] Firma Responsable TI: _____ Firma CISO:

=====

6.4 MONITOREO, MEDICIÓN E INDICADORES CLAVE DE RENDIMIENTO (KPIs)

Para garantizar que el SGSI no sea un documento estático y comprobar la efectividad real de las políticas redactadas en la Sección 5, se establece un **Cuadro de Mando de Seguridad**. Los siguientes KPIs serán medidos de forma automatizada y reportados mensualmente al Comité de Seguridad:

1. KPI de Efectividad contra Ransomware (Control de Backups)

- **Indicador:** Tasa de éxito en pruebas de restauración de bases de datos críticas.
- **Fórmula:** (Número de restauraciones mensuales exitosas en VirtualBox / Total de pruebas programadas) × 100
- **Meta Institucional: 100%.** Cualquier desviación menor implica una revisión técnica inmediata del script de copia de seguridad.

2. KPI de Contención Perimetral (Control de Redes)

- **Indicador:** Porcentaje de falsos positivos en las alertas del IDS/IPS.
- **Fórmula:** (Número de alertas reales confirmadas / Total de alertas emitidas por Suricata) × 100
- **Meta Institucional:** Mayor al **85%** (Asegura que las reglas de iptables y firmas de Suricata están correctamente optimizadas y no sobrecargan al equipo técnico).

3. KPI de Adopción de Identidad Segura (Control de Accesos)

- **Indicador:** Porcentaje de usuarios activos con el MFA correctamente enrolado.
- **Fórmula:** (Número de cuentas con MFA activo / Total de cuentas de usuario habilitadas en el SIS) × 100

- **Meta Institucional:** 100% para personal administrativo/TI; mayor al 95% para estudiantes en el primer semestre.

4. KPI de Cultura de Seguridad (Concienciación)

- **Indicador:** Tasa de apertura y clic en campañas controladas de simulación de phishing.
- **Fórmula:** $(\text{Número de empleados que introdujeron datos en el enlace de prueba} / \text{Total de empleados evaluados}) \times 100$
- **Meta Institucional:** Menor al 5% al finalizar las tres fases de capacitación establecidas en el plan.